AI THREAT LAB

Safe offline audits, transparent reports, and advisory AI analysis

Security Analysis Report

Project: E-Commerce Backend API

E-Commerce Backend API

Audit Date:	2026-10-20 21:59 UTC
Report Language:	English (en)
Analysis Scope:	Local static audit (offline)
Audit Status:	CANDIDATE_FINDINGS
AI Interpretation:	Google Gemini (gemini-2.5-flash)

Important Scope & Limitation Notice

This report contains the findings of an automated, offline static security analysis. All identified items represent candidate observations that require human context verification. This report does not constitute a full penetration test, certification, or guarantee of the absence of other vulnerabilities.

Executive & User Summary

The analysis identified a total of 3 finding(s) (P1: 1, P2: 1, P3: 1). All findings represent candidate observations requiring human context verification. Immediate attention is recommended for P1 items prior to deployment.

TOTAL THREATS	HIGH PRIORITY (P1)	MEDIUM (P2)	ITEMS SKIPPED
3	1	1	3

Detailed Threat Descriptions

Threat #1: Security audit observation (unspecified)

High Priority (P1)

Finding Status: Candidate for review | Location: src/tasks/exporter.py

What was detected?

Security audit observation (unspecified) ? location: src/tasks/exporter.py. Evidence:

Why is this potentially dangerous?

The analyzer recorded an observation for check `unspecified` based on: Requires human engineering review to determine impact in the target context.

Source Code Snippet

Source code is not accessible locally or file permissions restricted.

What should be checked?

Verify whether input reaching this operation originates from untrusted sources and is strictly validated.

How to fix this issue?

Zastąp wywołanie shell=True przekazaniem listy argumentów: subprocess.run(['tar', '-czf', archive, path], check=True, shell=False).

How to verify the fix?

Apply the recommended action (Zastąp wywołanie shell=True przekazaniem listy argumentów: subprocess.run(['tar', '-czf', archive, path], check=True, shell=False).) and re-run `ai-threat-lab`.

Analysis limitations

Partial static observation; not a confirmed vulnerability without context verification.

AI Interpretation (Google Gemini):

Threat #2: Security audit observation (unspecified)

Medium Priority (P2)

Finding Status: Candidate for review | Location: src/config/integrations.py

What was detected?

Security audit observation (unspecified) ? location: src/config/integrations.py. Evidence:

Why is this potentially dangerous?

The analyzer recorded an observation for check `unspecified` based on: Requires human engineering review to determine impact in the target context.

Source Code Snippet

Source code is not accessible locally or file permissions restricted.

What should be checked?

Verify whether input reaching this operation originates from untrusted sources and is strictly validated.

How to fix this issue?

Przenieś klucz do zmiennych środowiskowych lub bezpiecznego menedżera sekretów (np. os.environ['INTEGRATION_KEY']) i dodaj go do pliku .env.example.

How to verify the fix?

Apply the recommended action (Przenieś klucz do zmiennych środowiskowych lub bezpiecznego menedżera sekretów (np. os.environ['INTEGRATION_KEY']) i dodaj go do pliku .env.example.) and re-run `ai-threat-lab`.

Analysis limitations

Partial static observation; not a confirmed vulnerability without context verification.

AI Interpretation (Google Gemini):

Threat #3: Security audit observation (unspecified)

Low Priority (P3)

Finding Status: Candidate for review | Location: src/utils/checksum.py

What was detected?

Security audit observation (unspecified) ? location: src/utils/checksum.py. Evidence:

Why is this potentially dangerous?

The analyzer recorded an observation for check `unspecified` based on: Requires human engineering review to determine impact in the target context.

Source Code Snippet

Source code is not accessible locally or file permissions restricted.

What should be checked?

Verify whether input reaching this operation originates from untrusted sources and is strictly validated.

How to fix this issue?

Zastąp hashlib.md5 bezpiecznym algorytmem hashlib.sha256.

How to verify the fix?

Apply the recommended action (Zastąp hashlib.md5 bezpiecznym algorytmem hashlib.sha256.) and re-run `ai-threat-lab`.

Analysis limitations

Partial static observation; not a confirmed vulnerability without context verification.

AI Interpretation (Google Gemini):

Advisory AI Interpretation (Google Gemini)

Model Advisory Summary:
The inspected codebase contains a high-priority command injection vulnerability in the export task and hardcoded credentials. Implementing the suggested remediations will protect the production environment against unauthorized takeover.

Analysis Limitations & Not Checked Scope

? {'tool_id': 'dynamic_taint_tracking', 'reason': 'Statyczna analiza offline nie śledzi przepływu danych w czasie wykonania programu.'}
? {'tool_id': 'network_port_audit', 'reason': 'Tryb audytu offline zabrania wysyłania pakietów sieciowych do badanych hostów.'}
? {'tool_id': 'binary_dependency_decompilation', 'reason': 'Zewnętrzne skompilowane biblioteki C (.dll/.so) zostały pominięte.'}